Zugangsdaten erneuern

Railway-Sicherheitsvorfall, 21./22.10.2026 · WinAgent

Anlass: Mail von Railway Support. Railway empfiehlt, alle in Railway gespeicherten Umgebungsvariablen (API-Keys, Passwörter, Registry-Zugänge) zu widerrufen und neu auszustellen. Die Mail ist echt (SPF/DKIM/DMARC bestanden) und der Vorfall steht auf status.railway.com.

Regeln:

- Keine Links aus der Mail anklicken. Direkt railway.com und status.railway.com aufrufen.
- Neue Werte nicht in Chats, Mails oder Dateien im Projekt ablegen. Nur in Railway bzw. im Passwortmanager.
- Zufallswerte lokal erzeugen: `py -c "import secrets; print(secrets.token_urlsafe(48))"`

Stand Prüfung Code: Keine Geheimnisse im Repository oder in der Git-Historie. Alle Zugangsdaten liegen nur in den Railway-Variablen.

1. Railway-Konto

- [ ] Neu anmelden (Sitzungen wurden von Railway ungültig gemacht)
- [ ] 2FA aktiv?
- [ ] GitHub-Verbindung neu herstellen
- [ ] Neue Railway-API-Tokens erzeugen, falls welche genutzt werden
- [ ] Teammitglieder und Zugriffe prüfen

2. Neue Werte bei den Anbietern erzeugen (alte noch NICHT löschen)

	Variable	Wo erneuern	Hinweis
☐	DATABASE_URL	Railway, Postgres-Service: Zugangsdaten rotieren	App braucht danach Redeploy
☐	SECRET_KEY	neuer Zufallswert	alle Benutzer werden abgemeldet
☐	INGEST_TOKEN	in Railway LÖSCHEN, wenn keine Dateien per HTTP an die App geschickt werden	ohne Token ist die Upload-Schnittstelle abgeschaltet; sonst neuer Zufallswert
☐	REYBEX_USERNAME / REYBEX_PASSWORD	in Railway LÖSCHEN (Reybex wird nicht mehr genutzt)	zusätzlich Passwort bei Reybex ändern
☐	MS_CLIENT_SECRET	Microsoft Entra, App-Registrierung: neues Client-Secret	altes danach löschen
☐	RESEND_API_KEY	Resend: neuen Key erzeugen	nur falls genutzt
☐	SMTP_PASSWORD	beim Mailanbieter	nur falls genutzt

Keine Geheimnisse (nicht ändern): MS_TENANT_ID, MS_CLIENT_ID, MS_SENDER_EMAIL, RESEND_FROM, SMTP_FROM, SMTP_USER.

Außerhalb der Variablen:

- [ ] Datenexport-Feeds (feedToken) in Reybex löschen. Die App speichert die Links nicht mehr: Der Feed-Code wurde entfernt, gespeicherte Links werden beim nächsten Deploy aus der Datenbank gelöscht.
- [ ] Falls SmartBill-Zugangsdaten irgendwo bei Railway hinterlegt sind: erneuern.

3. In Railway eintragen

- [ ] Alle neuen Werte in einem Rutsch setzen (ein Deploy). Railway-Builds waren zeitweise eingeschränkt, notfalls warten.
- [ ] Deploy erfolgreich?

4. Alte Zugangsdaten löschen

- [ ] Reybex: Passwort geändert und Datenexport-Feeds gelöscht
- [ ] Microsoft Entra: altes Client-Secret löschen
- [ ] Resend: alten Key löschen
- [ ] Postgres: alte Zugangsdaten sind nach der Rotation ungültig

5. Funktionsprüfung

- [ ] Anmelden, Rechnungen öffnen
- [ ] Bericht "Jetzt senden" (prüft die Mail-Zugangsdaten)
- [ ] Wechselkurse "Kurse aus dem Netz aktualisieren"

6. Logs seit ca. 21.10. prüfen

- [ ] Railway-Logs der Services
- [ ] Reybex: Zugriffe und Anmeldungen (falls noch ein Konto besteht)
- [ ] Microsoft: Anmeldeprotokolle der App
- [ ] Resend: Versand-Log
- [ ] Datenbank: ungewöhnliche Verbindungen oder Abfragen

7. Datenschutz

- [ ] Benutzerpasswörter zurücksetzen (Passwort-Hashes lagen in der Datenbank)
- [ ] Meldepflicht nach DSGVO prüfen, sobald Railway bestätigt, ob das Projekt betroffen ist (Kundenadressen und E-Mail-Adressen liegen in der Datenbank)